Introduction to Bioinformatics

Data protection & compliance

Matej Hrnčiar

05. 05. 2026

Why data protection matters

- Bioinformatics routinely handles **genetic and health data**, which are among the most sensitive data types
- Genomic data is **inherently identifiable** (cannot be fully anonymised)
- Breaches can lead to:
  - Loss of trust
  - Legal penalties
  - Harm through discrimination or stigmatization (insurance, employment)
- Data protection is a **shared responsibility** of clinicians, researchers, and bioinformaticians

Regulatory frameworks - GDPR

- Applies to *any* personal data of EU residents
- No specific focus - applies to many aspects of subject's life, not just healthcare
- Genetic and health data are **special category data**
- **Requires lawful basis**:
  - Informed consent
  - Public interest research
- **Strong rights for data subjects**: access, erasure, withdrawal

Regulatory frameworks - HIPAA

- Applies to protected health information of US residents
- **Focus on healthcare and clinical research**
- **Defines 18 identifiers that must be removed for de-identification**:
  - Names, contact information, geographical identifiers, dates (except year)
  - Social Security numbers, medical record numbers, health insurance numbers
  - Biometric identifiers, photographs
  - URLs and IPs related to subjects

What types of data are involved?

- **Personal data**: name, date of birth, contact information
- **Health data**: diagnoses, lab results, clinical notes
- **Genomic data**: raw sequencing files, variants, expression profiles
- **Metadata**: demographics, cohort information, sample collection details
- Even indirect identifiers can enable **re-identification when combined**

How should we deal with following data?

Name

Date of birth

Phone number

Address

Family history

Patient ID

Email

Date of death

Age

Birth number

TNM status

Marital status

Blood test results

Prescribed medication

Allergies

Workplace

Neoadjuvant therapy?

Income

Genetic test results

Last checkup date

ICD diagnosis

Data protection principles

How should we work with personal data?

Purpose limitation

- Data can be used only for **explicitly stated research purposes**
- If the subject agrees on specific type of analysis, it is **not allowed to use the data on "interesting additional analysis"**
- Reusing datasets for new analyses is **not automatically allowed**
- Secondary use requires:
  - Compatibility with original purpose
  - New consent or authorisation

Data minimisation

- Before collecting the patient's data, ask yourself **"Do I really need this data to answer the research question?"**
- Avoid excess metadata and identifiers not required for analysis
- For example, stool properties can be relevant for colorectal cancer patients, **but not for patients with brain tumour**

Security safeguards

- Data must be protected against:
  - Unauthorised access
  - Accidental loss
  - De-identification
- **Technical measures**: encryption, secure servers, access control
- **Organisational measures**: training, policies

Accountability

- Researchers must be able to **demonstrate compliance**
- NDAs, consent forms, access logs
- “I didn’t know” is not an acceptable excuse

Data protection guidelines

What to do with personal data?

Informed consent

- **Consent defines what analyses are legally and ethically allowed**
- **Informed, voluntary, transparent, and documented**
- Clear about data collection, storage, and sharing
- **Can be withdrawn** - data must be removed
- Common models:
  - Specific consent - data can be used only for specific study
  - Broad consent - data can be used in future related research
- **Informed consent must be approved by ethical committee**

INFORMOVANÝ SÚHLAS PACIENTA

Názov štúdie: Názov

Výskum realizuje: Fakulta informatiky a informačných technológií, Slovenská technická univerzita v Bratislave

Úvod

Tento dokument predstavuje informovaný súhlas pacienta na odber tkaniva za účelom vykonávania vedeckého výskumu v oblasti personalizovanej medicíny. Prosím, prečítajte si ho pozorne, aby ste pochopili ciele a charakter výskumu, ako aj svoje práva a povinnosti. V prípade akýchkoľvek otázok sa neváhajte obrátiť na zodpovednú osobu uvedenú nižšie.

Cieľ výskumu

Odoberané tkanivo bude využité na identifikáciu genetických a molekulárnych zmien spojených s rozvojom a progresiou rakoviny. Cieľom výskumu je vývoj systému, ktorý bude odporúčať najvhodnejšiu liečbu na základe identifikovaných mutácií. Výsledky môžu prispieť k lepšiemu pochopeniu mechanizmov vzniku ochorenia a k vývoju nových diagnostických a terapeutických prístupov, ako aj urýchleniu výberu liečby, ktorá bude stanovená presne pre konkrétneho pacienta.

Dôvernosť údajov

Vaše osobné údaje a zdravotné informácie budú spracúvané v súlade s platnými právnymi predpismi a ochranou osobných údajov. Tkanivo bude anonymizované pred jeho použitím na výskum, čím sa zaručí, že nebude možné priradiť ho k Vašej osobe.

V súlade s nariadením Európskeho parlamentu a Rady (EÚ) 2016/679 o ochrane fyzických osôb pri spracúvaní osobných údajov (GDPR) budú Vaše údaje spracúvané výhradne na vedecké účely. Nebudú poskytované tretím stranám bez Vášho výslovného súhlasu a budú uchovávané bezpečne počas celej doby trvania výskumu. Kedykoľvek máte právo požiadať o prístup k svojim údajom, ich opravu alebo vymazanie, ak to nebude v rozpore s oprávnenými záujmami výskumu.

Dobrovoľný charakter účasti

Vaša účasť v tomto výskume je dobrovoľná. Môžete ju kedykoľvek odvolať bez uvedenia dôvodu a bez akéhokoľvek negatívneho dopadu na Vašu zdravotnú starostlivosť.

Kontaktné informácie

Zodpovedná osoba: [Meno a priezvisko]

Telefón: [Telefónne číslo]

E-mail: [E-mailová adresa]

Súhlas pacienta

Ja, dolupodpísaný/-á, som si prečítal/-a tento dokument, porozumel/-a jeho obsahu a mal/-a možnosť klásť otázky. Dobrovoľne súhlasím s odberom tkaniva na účely uvedené vo výskume.

Meno a priezvisko: _____

Dátum: _____ Podpis: _____

Anonymisation & pseudonymisation

- **Anonymisation**:
  - Irreversible removal of identifiers
  - Data no longer regulated under GDPR
  - Rarely achievable for genomic data
- **Pseudonymisation**:
  - Identifiers replaced with codes
  - Re-identification possible with key
  - Still considered personal data under GDPR

Data access control & security

- Access limited to authorised personnel
- Role-based access control
- **Secure environment**: encrypted storage, secure compute clusters
- Access must be logged and auditable
- **Issues with analysis in cloud**: the data must be physically located in the country's territory, which is not guaranteed in cloud

Data sharing

- **FAIR principles**:
  - **Findable**: unique identifiers, easy to locate through search
  - **Accessible**: retrievable, clear protocols for access, ensuring transparency
  - **Interoperable**: standard formats and vocabularies to be integrated with other datasets and applications
  - **Reusable**: well-described, sufficient metadata, a clear license, and provenance for replication and reuse in different settings - **important in research**
- **Informed consent must contain clause about data sharing, otherwise it is not allowed**
- **Accessible does not mean publicly available**

AGREEMENT ON THE TRANSFER OF PSEUDONYMIZED PERSONAL DATA
(for academic research from [redacted]

This agreement (hereinafter referred to as "Agreement") is made and entered by and between:

[redacted] having its registered office and principal place of business in at [redacted] legally represented by the undersigned, hereinafter referred to as "PROVIDER"

and

Faculty of Informatics and Information Technologies, Slovak University of Technology, having its registered office and principal place of business at Ilkovicova 2, 842 16 Bratislava, Slovakia, legally represented by the undersigned, hereinafter referred to as "RECIPIENT".

PROVIDER and RECIPIENT hereinafter jointly referred to as "Parties" and individually as "Party";

WHEREAS

a. PROVIDER has obtained and/or generated DATA as further defined below and stores such DATA in its institutional Biobank, always with informed consent of the SUBJECT;
b. RECIPIENT wishes to use the Data to conduct non-commercial scientific research as described in Annex I;
c. RECIPIENT, through [redacted] hereinafter referred to as "RECIPIENT SCIENTIST", has requested PROVIDER to provide RECIPIENT with the DATA for use by RECIPIENT'S SCIENTIST for the purpose of its RECIPIENT'S RESEARCH PLAN entitled: [redacted]
d. The purpose and means of RECIPIENT'S RESEARCH PLAN have been determined by RECIPIENT;
e. PROVIDER is willing, subject to the terms and conditions of this Agreement, to provide the DATA to RECIPIENT.

I Definitions

1. DATA: the data being transferred under this Agreement is the data that is further specified in Annex I to this Agreement, provided without directly identifying personal information. The DATA constitutes pseudonymized personal health data under the GDPR.
2. RECIPIENT'S RESEARCH PLAN: The research plan specified in Annex I to this Agreement for which the DATA may be used.
3. EFFECTIVE DATE: The date of last signing of this Agreement.
4. INVENTION: any invention, discovery , improvement, material, signal, process, formula, know-how

ANNEX I

Description of the DATA, methods of transfer and storage, allowed processors

Biobank and Data Access Committee (BDAC)
Number of approved request: [redacted]
or
EGA dataset(s) reference: [redacted]
or
Dataset reference, other:

Brief abstract of the Recipient Research Project in which the Material and Data will be used (500 words max):

[redacted]

Data subjects
The personal data transferred concern the following categories of data subjects:

[redacted]

Purposes of the transfer(s):
The transfer is made to perform the project as described in the abstract. The transferred data will solely be used for health, medical or biomedical research.
The data can never be used to perform germline analyses.

Questions?